

Daiichi Retell AI Dashboard

User Roles, Page Access and Permission Audit

Current implementation

1. Access Model

The application has two role systems: **platform roles** for Daiichi staff and **tenant roles** for client workspace users. Effective access is the union of applicable roles, restricted by profile status, active membership, tenant scope, individual agent grants, server permission checks and Supabase Row-Level Security.

2. Client Workspace Roles

Role	Granted capabilities	Management
Owner	Agents, calls, chats, transcripts, recording playback, analytics and billing read	Read-only
Admin	Same as Owner	Read-only
Manager	Agents, calls, chats, transcripts, recordings and analytics	Read-only
Analyst	Agents, calls, chats and analytics	Read-only
Viewer	Agents, calls, chats and analytics; initiate/respond permissions exist	No management UI
Billing	Tenant and billing read	No usable dashboard page

Client Page Visibility

Page	Permission	Owner/Admin	Manager	Analyst	Viewer	Billing
Home	analytics.read	Yes	Yes	Yes	Yes	No
Agents	agents.read	Yes	Yes	Yes	Yes	No
Phone Numbers	agents.read	Yes	Yes	Yes	Yes	No
Call History	calls.read	Yes	Yes	Yes	Yes	No
Chat History	chats.read	Yes	Yes	Yes	Yes	No
Contacts	calls.read	Yes	Yes	Yes	Yes	No
Analytics	analytics.read	Yes	Yes	Yes	Yes	No
Team	members.read	No	No	No	No	No

Agent-level restriction: Client users see only agents with active individual grants. Calls, chats, contacts, analytics, phone numbers, metrics and charts are filtered to those agents.

3. Platform Roles

Role	Can view	Can manage	Restrictions
Super Admin	All platform and tenant data	All functions	None in permission model
Operations Admin	Tenants, members, agents, calls, chats, transcripts, recordings, analytics, audit	Tenants, members, agents, Retell, reconciliation, exports	No platform-admin or billing management
Agent Engineer	Tenants, agents, calls, chats, transcripts, recordings, analytics	Agents	Cannot run full import
Quality Analyst	Tenants, agents, calls, chats, transcripts, recordings, analytics	Report export	No operational management
Support	Tenants, members, agents, calls, chats, analytics	None	No transcripts, recordings or exports
Billing Admin	Tenants, billing, analytics, audit	Billing	Cannot enter Owner Dashboard
Auditor	Tenants, agents, analytics, billing, audit	None	No formal call/chat permission

4. Platform Control Center

Opening **/admin** requires **tenants.read**. All current platform roles have this permission.

Operation	Required access
View Control Center	tenants.read
Sync Retell data	agents.manage + retell_connections.manage
Manage platform administrators	super_admin
Manage client users	members.manage
Grant/revoke agent access	members.manage + agents.manage
Assign agents	agents.manage
View as client user	members.manage
Manage invoices	billing.manage
Manage contacts, fields and backfills	retell_connections.manage

5. Security Behavior

- Inactive or suspended profiles cannot use the application.
- Only active memberships are accepted.
- Platform roles may be global or tenant-scoped.
- Tenant-scoped roles do not apply to other tenants.
- Each agent can have only one active tenant assignment.
- Agent grants can be revoked without deleting history.
- Calls and chats are tenant-scoped and protected by server checks and RLS.
- Unauthorized protected routes generally return not-found.
- Administrative mutations create audit records where implemented.

6. Current Authorization Gaps

1. **Owner and Admin are read-only** despite their administrative names.
2. **Billing users have no usable billing page** and may receive a not-found dashboard.
3. **No tenant role can open Team** because none receives members.read.
4. Viewer has calls.initiate and chats.respond while senior roles do not.
5. Permission overrides are stored but not applied by the authorization context.
6. **Owner Dashboard overexposure:** all views are returned after only agents.read is accepted.
7. Contact management controls may be visible when the protected API will reject the action.
8. Control Center summaries are visible to every platform role.
9. Tenant recording flags are not applied by the dashboard loader.
10. contacts.view_unmasked has no implemented workflow.
11. Some exports are not hidden when reports.export is absent.
12. Agent Version analytics is unavailable because version is missing from call data.

7. Recommended Priority

1. Apply page-level permissions to Owner Dashboard.
2. Hide unauthorized management controls.
3. Define meaningful differences for Owner, Admin and Manager.
4. Create a billing page for Billing users.
5. Apply membership permission overrides.
6. Enforce recording, transcript, export and contact-unmasking settings.
7. Add automated access tests for every role and route.